# Profil entreprise - Bruno Moyse / nuagemagique.dev

Conformément au §I.F du Manuel de certification SCE 2.0, ce document décrit :

- l'organisation du producteur du système de caisse,
- ses contrôles internes,
- son analyse de risques,
- sa conformité GDPR,
- ses certifications externes.

## 1. Identification

| Champ | Valeur |
|---|---|
| Nom légal | Bruno Moyse |
| Nom commercial | nuagemagique.dev |
| Forme juridique | Personne physique (entreprise individuelle, régime franchise TVA art. 56 §2 CTVA) |
| Adresse | Rue Joseph Claes 4/1, 1060 Saint-Gilles, Belgique |
| Numéro d'identification à la TVA / d'entreprise | BE 0783.544.917 (numéro d'entreprise BCE ; régime de franchise de TVA, art. 56 §2 CTVA) |
| Site web | https://nuagemagique.dev |
| Email de contact | cloud@nuagemagique.dev |
| Téléphone | +32 494 46 50 26 |
| Représentant autorisé | Bruno Moyse (signataire unique) |
| Contact technique | Bruno Moyse |

## 2. Activité

nuagemagique.dev développe et déploie des systèmes logiciels sur mesure pour le secteur HoReCa et la restauration. Le système de caisse `pili-pos` est le premier produit soumis à certification SCE 2.0.

## 3. Organisation du développement

### 3.1 Modèle de développement

Développement **en interne, sans sous-traitance**. Bruno Moyse est l'unique développeur.

### 3.2 Nombre de développeurs

| Rôle | Effectif |
|---|---|
| Développeurs (interne) | 1 |
| Développeurs (externe / freelance) | 0 |
| QA / testeurs | 0 (couvert par le développeur) |
| Personnel d'exploitation | 0 (déployé chez le client) |

### 3.3 Outils de développement

- **Contrôle de version** : git, dépôt privé sur GitHub (`github.com/nuagemagique/pili-pos` ou équivalent).
- **Suivi des modifications** : historique git (chaque commit porte son auteur et sa date) ; la build soumise est identifiée par un tag de version (v`X.Y.Z`) et par le SHA-1 du binaire (§I.D du formulaire). Les commits et les tags ne sont pas signés GPG.

- **CI/CD** : GitHub Actions pour les tests et la construction reproductible des binaires.
- **Toolchain Rust** : épinglée à une version stable spécifique (`rust-toolchain.toml` à la racine du dépôt).
- **Build reproductible** : `Cargo.lock` committé ; même hash binaire pour deux builds successifs sur la même machine et même toolchain.

## 4. Contrôles internes

### 4.1 Revue de code

Toute modification du code source passe par une **pull request** sur git. Les modifications affectant le code fiscal (`crates/pos-fiscal`, `crates/pos-db/src/schema.rs`, `crates/pos-engine/src/commands/`) sont revues avec une attention particulière :

- Vérification mécanique de l'absence de `DELETE FROM fiscal_events` et `UPDATE fiscal_events SET ...` dans la diff (cf. `DECLARATION_FONCTIONS_INTERDITES_FR.md`).
- Tests CI obligatoires verts avant fusion :
  - `cargo build --no-default-features --features cert` doit passer.
  - `cargo test --workspace` doit être 100 % vert.
  - `cargo clippy --workspace -- -D warnings` doit être propre.
  - `cargo fmt --all --check` doit être propre.
- Tests e2e SPF (Basic Set + Reports + no-gap) doivent rester verts.

Comme l'effectif est de 1 développeur, l'auto-revue est mitigée par l'outillage automatisé (clippy, tests, scripts CI), et par l'utilisation systématique d'agents d'audit (revue par IA indépendante via `ultrareview` ou équivalent) avant toute soumission ou release.

### 4.2 Versioning et changelog

Chaque release est tagged en `vX.Y.Z` avec un changelog Markdown décrivant les modifications.

Une release post-certification déclenchera : 1. Création d'un changelog documentant les modifications. 2. Recalcul du SHA-1 du nouveau binaire. 3. Soumission au SPF Finances (procédure post-cert décrite dans `MANUEL_INTRO_FR §C` du manuel SCE 2.0, traitement sous 15 jours).

### 4.3 Conservation des journaux

- **Logs de développement** : git log permanent, jamais purgé.
- **Logs de CI** : conservés 90 jours sur GitHub Actions, puis archivés.
- **Logs en production chez le client** : voir `FEUILLE_ACQUISITION_DONNEES_FR.md` §1.3 - rotation quotidienne sans purge automatique.

### 4.4 Accès au code source

- Dépôt git **privé**, accès limité au développeur.
- Pas de partage du code source aux clients ; le distributeur est le développeur.
- Le code source sera communiqué au SPF Finances **sur demande** pour audit, sous accord de confidentialité standard.

### 4.5 Gestion des incidents

En cas de découverte d'un bug critique en production :

1. Reproduction locale et écriture d'un test de régression reproduisant l'incident.
2. Correction dans une branche dédiée.
3. Revue automatisée + tests CI verts.
4. Si le bug affecte le périmètre certifié : déclaration au SPF Finances dans les 15 jours suivant le déploiement de la correction.
5. Communication aux clients concernés avec instructions de contournement le cas échéant.

### 4.6 Accès du distributeur aux machines déployées

Le distributeur (= développeur dans le cas présent) accède aux machines déployées **uniquement** :

- À l'installation initiale, en présence physique chez le client.
- Pour les mises à jour : sur site (clé USB).
- Pour le support : sur site, ou par une session RustDesk qu'un Gérant démarre depuis la caisse avec son PIN (le kiosque n'a pas de serveur SSH ni de port en écoute).

Aucun accès à distance permanent n'est implémenté ni autorisé (cf. `GARANTIE_MAJ_LANGUES_FR.md` §2.2), ce qui limite la surface d'attaque réseau côté client au temps d'une intervention.

## 5. Analyse de risques

### 5.1 Risques techniques

| Risque | Probabilité | Impact | Mitigation |
|---|---|---|---|
| Panne disque SSD du kiosque | Moyenne | Élevé | Sauvegarde journalière avant Z (cf. `FEUILLE_ACQUISITION_DONNEES_` Procédure de remplacement disque documentée. |
| Perte d'alimentation pendant une transaction | Élevée | Faible | WAL SQLite + transactions atomiques. Aucun événement à moitié écrit. |
| Coupure réseau LAN entre POS et FDM | Élevée | Moyen | Mode bloquant en build cert ; l'opérateur réessaie quand le FDM revient. Aucune transaction enregistrée hors FDM. Une requête dont la réponse est perdue est conservée et renvoyée à l'identique (jamais perdue ni doublée). Elle bloque la signature tant que le FDM ne répond pas : procédure technicien dans `MANUEL_INSTALLATION_FR.md` §7.5. |
| FDM qui a perdu sa mémoire des doublons | Faible | Moyen | Le renvoi d'une requête perdue serait signé comme un nouvel événement. Détecté par les compteurs, journalisé, non évitable par le POS. |
| Action de l'écran en attente derrière un Z automatique ou un renvoi | Faible | Faible | Attente de 30 s au plus, puis message `signing_busy` ; l'opérateur réessaie. |

| Risque | Probabilité | Impact | Mitigation |
|---|---|---|---|
| Coupure réseau internet du FDM | Moyenne | Variable | Hors du périmètre POS (responsabilité du FDM). Le POS continue à enregistrer localement et le FDM rejoue ses propres données à reconnexion. |
| Erreur d'horloge système | Faible | Moyen | NTP `chrony` actif, BIOS battery vérifiée à l'installation. |
| Vulnérabilité dans une dépendance Rust | Moyenne | Variable | Audit `cargo audit` mensuel. Patch & rebuild & recertification mineure si nécessaire. |
| Bug dans le code applicatif | Faible | Variable | Tests automatisés unitaires, d'intégration et e2e applicatifs (totaux dans `RAP-PORT_TESTS_BASELINE_FR.md`). Régressions attrapées en CI. |

**5.2 Risques humains**

| Risque | Probabilité | Impact | Mitigation |
|---|---|---|---|
| Erreur de saisie d'INSZ | Élevée | Faible | Validation mod-97 ; rejet immédiat avec message d'erreur clair. |
| Tentative de manipulation des compteurs | Faible | Élevé | Image scellée, pas d'accès shell ; la base n'est ouverte qu'en lecture seule (`pos-db-ro`) et `fiscal_events` est protégée par des déclencheurs SQLite. Signature FDM détecte toute falsification a posteriori. |
| Apprenti effectuant un encaissement | Faible | Faible | Profil Apprenti bloqué au niveau commande ; tentative renvoyée à un Serveur. |

| Risque | Probabilité | Impact | Mitigation |
|---|---|---|---|
| Distributeur compromis (accès au dépôt ou au poste de développement) | Faible | Élevé | Le SHA-1 déclaré au SPF Finances identifie la build certifiée ; `deploy/update.sh --sha1` refuse tout binaire dont le SHA-1 diffère ; la build en conteneur est reproductible, vérifiée par deux builds en CI. |

### 5.3 Risques réglementaires

| Risque | Probabilité | Impact | Mitigation |
|---|---|---|---|
| Modification spec SCE 2.0 (Addendum) | Élevée | Variable | Veille mensuelle sur `systemedecaisseen-registreuse.be`. Délai 90 j minimum entre publication et mise en conformité. |
| Refus de certification | Moyenne | Élevé | Répétition pré-soumission contre FDM virtuel (cf. `JOURNAL_TESTS_PRE_SOUMISSION_FR.md`). Préparation soignée des documents du dossier. |
| Cooldown 3 mois en cas de refus | - | Élevé | Idem - pré-soumission rehearsal sérieuse. |

## 6. Conformité GDPR (RGPD)

### 6.1 Données personnelles traitées

| Donnée | Sujet concerné | Base légale | Stockage |
|---|---|---|---|
| INSZ (Numéro National Belge, 11 chiffres) | Employé du restaurant | Art. 6.1.c - Obligation légale fiscale et sociale | `users.insz`, `orders.user_insz`, `fiscal_events.user_insz`, payload FDM |
| Nom de l'employé | Employé | Art. 6.1.c - Obligation contractuelle | `users.name` |
| Code PIN (haché bcrypt) | Employé | Art. 6.1.f - Intérêt légitime (sécurité opérationnelle) | `users.pin_hash` |

| Donnée | Sujet concerné | Base légale | Stockage |
|---|---|---|---|
| Empreinte du badge d'un employé (HMAC-SHA256, jamais le numéro du badge), historique des liens et retraits, journal des passages (heure, INSZ, résultat) ; option désactivée par défaut | Employé | Art. 6.1.f - Intérêt légitime de l'employeur (enregistrer la présence, art. 1, 9° et art. 9 de l'AM du 29 avril 2024, et sécuriser l'accès à la caisse) | `staff_badges.badge_hash`, `badge_log`, `badge_scans` ; la clé n'est pas dans la base (`badge.key`) |
| TVA client B2B | Client professionnel | Art. 6.1.c - Obligation légale facturation | `peppol_deliveries.customer_endp` payload UBL |
| Nom et adresse client B2B | Client professionnel | Idem | Payload UBL stocké dans `pep–pol_deliveries.ubl_xml` |
| Nom, téléphone et adresse de livraison du client d'une commande en ligne (HubRise, activé par installation, coupé par défaut) | Client B2C | Art. 6.1.b - Exécution de la commande passée par le client auprès du webshop ou de la plateforme | `orders.raw_hubrise_json`, `hubrise_events.payload_json` (JSON reçu de HubRise) ; bon client non fiscal imprimé |
| Adresse e-mail (ticket numérique, §III.H) | Client B2C | Art. 6.1.a - Consentement/demande explicite du client à la caisse (le support "E-mail" n'est jamais activé par défaut ; l'opérateur ne le choisit qu'à la demande du client) | `ticket_deliveries.recipient` (en clair, 72 h max) puis `recipient_hint` (masqué, indéfiniment) |

Les **données client B2C** traitées sont : l'adresse e-mail du ticket numérique, sur demande explicite et ponctuelle du client à la caisse ; et, seulement quand les commandes en ligne sont activées, le nom, le téléphone et l'adresse de livraison que HubRise transmet avec la commande (`COMMANDES_EN_LIGNE_FR.md` §3 bis). Pas de programme de fidélité, pas de tracking, pas de WiFi guest, pas de base clients.

**Badge du personnel (lecteur de badges, option).** Quand l'établissement active le lecteur de badges (désactivé par défaut), un badge (carte ou porte-clés) peut servir à pointer sa présence et à se connecter à la caisse (Serveurs et Apprentis ; un Gérant garde son PIN). Garanties :

- **aucune donnée biométrique** : seul le numéro de série du badge est lu, jamais un contenu, une empreinte digitale ni un visage ;
- **empreinte seule** : le numéro n'est jamais écrit (ni dans la base, ni dans les journaux, ni dans un événement) ; la caisse conserve une empreinte HMAC-SHA256 calculée avec une clé secrète de 32 octets propre au terminal (`badge.key`, créée sur place, mode 0600). La clé **ne quitte jamais le terminal** : elle est hors de `pos.db`, donc absente des sauvegardes et de l'export nocturne ; sans elle, l'empreinte ne permet pas de retrouver le numéro, même par énumération ;
- **finalité limitée** à l'enregistrement de la présence (événement S) et à la connexion à la caisse ; aucun suivi de déplacement, aucune autre exploitation du journal des passages ;
- **le badge est facultatif** : un employé peut le refuser, il garde son PIN et l'enregistrement de sa présence par un Gérant, sans conséquence ;
- **un retrait supprime l'accès** (le Gérant retire le badge, ou la désactivation de l'employé le retire) ; les lignes ne sont pas effacées, pour l'audit.

### 6.2 Bases légales détaillées

- **INSZ** : Article 25 de la loi du 30 juillet 2018 relative à la protection des personnes physiques à l'égard des traitements de données à caractère personnel ; obligation Dimona ONSS (article 9 bis de l'arrêté royal du 5 novembre 2002) ; obligation d'identification fiscale (article 21bis du Code de la TVA).
- **PIN haché** : intérêt légitime - sécurité du POS contre l'usurpation d'identité par d'autres employés.
- **Badge du personnel** : intérêt légitime de l'employeur (article 6.1.f RGPD) à enregistrer la présence du personnel, obligation sociale reprise par l'événement S, et à sécuriser l'accès à la caisse ; l'employé peut refuser le badge (PIN et enregistrement par un Gérant restent disponibles), ce qui évite d'en faire une condition d'emploi.
- **VAT client B2B** : obligation de facturation conforme (article 10 de l'arrêté royal n°1 du 29 décembre 1992).
- **Adresse e-mail (ticket numérique)** : consentement du client, donné à l'écran de caisse au moment de choisir "E-mail" ou "Les deux" (article 6.1.a RGPD). Aucune collecte n'a lieu pour un ticket "Papier" (le choix par défaut) ; l'adresse n'est jamais réutilisée au-delà de l'envoi de ce ticket précis (pas de fichier client, pas de ré-emploi marketing).

### 6.3 Durée de conservation

- **INSZ + nom employé** dans `users` : durée du contrat de travail
  - 7 ans (durée légale belge de conservation des documents fiscaux).
- **INSZ dans `fiscal_events`** : 7 ans minimum (durée légale).
- **TVA client B2B** : 7 ans (idem).
- **PIN haché** : durée du contrat de travail. À la fin du contrat, l'utilisateur est marqué `active = 0` mais NON supprimé (pour ne pas casser la FK depuis `fiscal_events`).
- **Badge** (`staff_badges`, `badge_log`, `badge_scans`) : conservés avec les données de présence de l'employé. Le retrait du badge ou la désactivation de l'employé met fin à l'accès sans effacer la ligne (ajout seul, pour l'audit) ; l'empreinte est inutilisable sans la clé du terminal, qui n'est jamais exportée ni sauvegardée.
- **Données client d'une commande en ligne** : conservées avec la commande (`orders.raw_hubrise_json`, `hubrise_events.payload_json`) ; aucune purge automatique n'est implémentée à ce jour.
- **Adresse e-mail (ticket numérique)** : 72 heures maximum en clair, effacée immédiatement dès l'envoi réussi ou le repli papier (`ticket_deliveries.recipient`, purge automatique - `TICKET_NUMERIQUE_FR.md` §7). Un indice masqué (ex. `j***@e***.be`, `recipient_hint`) subsiste indéfiniment, sans permettre de reconstituer l'adresse d'origine, pour la lisibilité du support technique et du dossier de certification.

### 6.4 Droits des personnes concernées

- **Droit d'accès** : sur demande écrite au responsable de traitement (Bruno Moyse, cloud@nuagemagique.dev), réponse sous 30 jours. Pour les employés, l'export de leur historique `fiscal_events` est extrait par requête SQL ciblée.
- **Droit de rectification** : limité par les obligations fiscales - un événement signé par le FDM ne peut pas être modifié. Une correction de nom est possible dans `users.name` sans impact sur les événements historiques (qui portent l'INSZ comme identifiant stable).
- **Droit à l'effacement** : INAPPLICABLE pour les données fiscalement obligatoires (article 17.3.b du RGPD - obligation légale supérieure).
- **Droit à la portabilité** : sur demande, export JSON/CSV des données concernées (cf. `FEUILLE_ACQUISITION_DONNEES`
- **Droit d'opposition** : INAPPLICABLE pour les obligations légales. Pour le badge, l'employé peut s'y opposer : il n'est jamais obligatoire.

### 6.5 Sous-traitants

**HubRise** (concentrateur de commandes en ligne ; connexion HTTPS sortante vers `api.hubrise.com`, seulement quand `hubrise_enabled` est activé) est la source des données client des commandes en ligne (§6.1) et leur intermédiaire technique entre le webshop ou la plateforme de livraison et la caisse. La caisse lui renvoie les statuts de commande et les ventes (lignes, totaux, paiements), sans données de client (`COMMANDES_EN_LIGNE_FR.md` §3 bis).

**Scaleway** (SAS de droit français, hébergement/traitement dans la région `fr-par`, Union européenne) est le sous-traitant de l'envoi du ticket numérique, via son API Transactional Email :

| Élément | Valeur |
|---|---|
| Finalité | Envoi du ticket numérique par e-mail, à la demande explicite du client à la caisse |
| Donnée transmise | Adresse e-mail du destinataire + contenu du ticket (texte, lien et QR de vérification FDM) |
| Localisation | Union européenne (région Scaleway `fr-par`, Paris) |
| Base légale du transfert | Pas de transfert hors UE ; sous-traitant soumis au RGPD |
| Durée de rétention côté producteur | 72 h maximum (§6.3) |
| Usage marketing | Aucun - API transactionnelle uniquement, pas de liste de diffusion |

Aucun autre service tiers ne reçoit de donnée personnelle issue de `pili-pos` ni ne lui en transmet (le FDM reçoit l'INSZ de l'opérateur, obligation légale, mais n'est pas un sous-traitant du producteur - c'est l'organe de contrôle SPF Finances).

### 6.6 Sécurité (article 32 RGPD)

Voir `SECURITE_BD_FR.md` pour le détail.

Synthèse : - Chiffrement au repos via FileVault / LUKS au niveau système d'exploitation (à activer à l'installation). - Chiffrement en transit : la liaison POS↔FDM peut être en HTTP si les deux appareils sont sur un LAN privé non routé (configuration de référence). Pour les déploiements multi-sites, HTTPS via VPN. - Authentification : PIN par utilisateur (optionnel), INSZ obligatoire. - Badges (option) : empreinte HMAC-SHA256 avec une clé propre au terminal hors de la base ; un Gérant n'est jamais connecté par un badge seul (PIN obligatoire) ; liens, retraits et passages journalisés en ajout seul (`SECURITE_BD_FR.md` §badges). - Audit log : `fiscal_events` couvre TOUTES les actions fiscales, horodatées et signées. - Sauvegarde : journalière, conservée localement.

### 6.7 Notification de violation

En cas de violation impliquant des données personnelles :

1. Évaluation de la gravité dans les 24 h.
2. Notification à l'Autorité de Protection des Données belge sous 72 h si la violation présente un risque pour les personnes concernées (article 33 RGPD).
3. Communication aux personnes concernées si risque élevé (article 34 RGPD).

### 6.8 Représentant DPO

Pour un effectif < 250 personnes sans traitement à grande échelle de données sensibles, la désignation d'un DPO n'est pas obligatoire (article 37.1 RGPD). Bruno Moyse exerce la fonction de point de contact GDPR de fait pour nuagemagique.dev.

## 7. Certifications externes

**Aucune certification externe** au moment de la soumission. - Pas d'ISO 9001. - Pas d'ISO 27001. - Pas de SOC 2.

L'effort de certification SCE 2.0 est la première démarche de certification formelle de nuagemagique.dev.

## 8. Assurance

À compléter lors de la signature du formulaire de demande de certification.

Une assurance Responsabilité Civile Professionnelle couvrant les développements logiciels est en cours de souscription auprès d'un courtier belge spécialisé pour indépendants tech.

## 9. Exigences de sécurité spécifiques au client

Aucun client n'a fixé d'exigences de sécurité spécifiques au-delà des exigences SCE 2.0 et RGPD standard. La configuration de sécurité décrite dans `SECURITE_BD_FR.md` est appliquée par défaut.